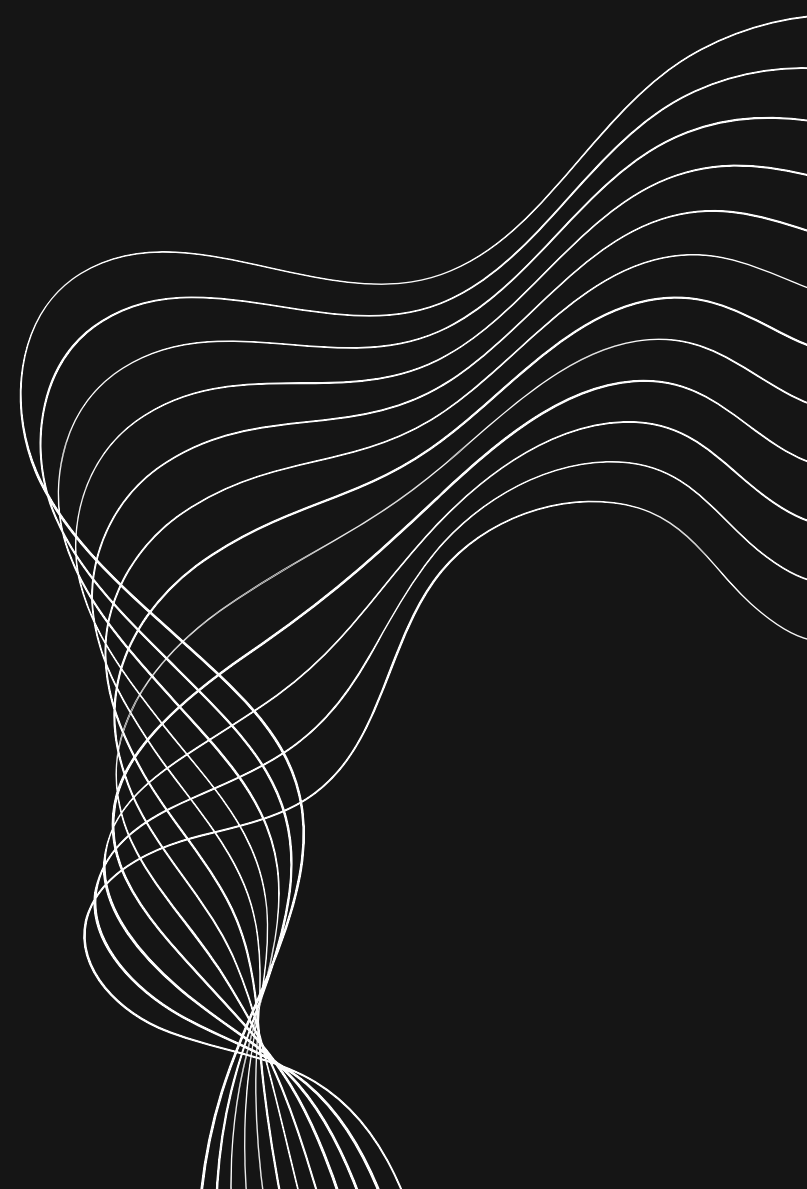




Cyber Security



Charlotte Emma Whiting

CONTENT - WEEK 1

3-7

Q1. DIFFERENCES IN VULNERABILITY, THREAT AND ATTACK

8-11

Q2. RANSOMWARE ATTACKS WITH CRYPTOCURRENCY

12-14

Q3. LINUX SYSTEMS - /ETC/PASSWD/ETC PURPOSES AND FUNCTIONALITY

15-21

Q4. VULNERABILITY SCAN AND ASSESSMENT

22 -25

Q5. RECONNAISSANCE SCAN.OPEN PORTS / SERVICES/ HOSTNAME / OPERATING SYSTEM & VERSION

Q1. DIFFERENCES IN VULNERABILITY, THREAT AND ATTACK



DIFFERENCES

Vulnerability

Vulnerabilities can be a flaw in a systems design, security procedures, internal controls etc that can be exploited by cyber criminals. Occasionally created by cyber attacks or if an employee downloads a virus or social attack

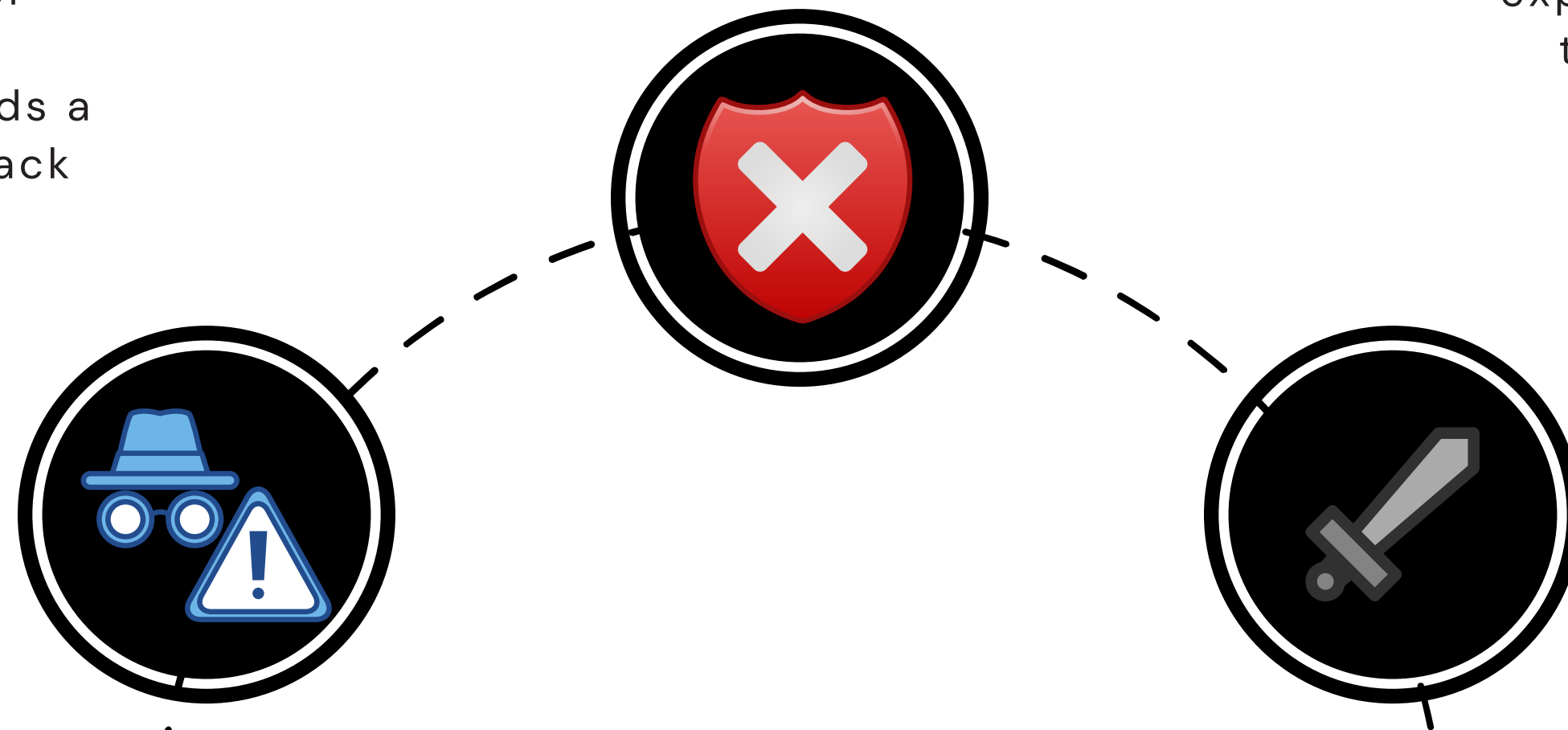
Threat

There are 3 types:

1. Intentional – Malware, phishing, accessing others accounts illegally for example
2. Unintentional – Caused by human error. Could be not updating antivirus or updating the firewall
3. Natural – Natural disasters can damage data so are known as natural threats

Attack

- Malicious
- Unauthorised
- Compromises CIA and AAA
- They can vary in complexity, impact, objectives and exploit vulnerability to compromise digital assets



VULNERABILITY

In May 2024, Ticketmaster, one of the world's largest ticket sales companies, fell victim to a significant cyberattack. The breach exposed sensitive customer information, including payment details and personal data, causing concern among millions of users. This incident has been linked to the notorious cybercriminal group, ShinyHunters, who have a long history of high-profile data breaches and ransomware attacks.

- The attackers gained access to the company's network by exploiting a vulnerability in their customer service portal.
- Once inside, they exfiltrated customer data, including names, email addresses, payment information, and ticket purchase histories.
- By the time Ticketmaster gained control of the attack, customer information was being sold on the dark web.



THREAT

A European subsidiary of the Toyota Group, Toyota Boshoku Corporation, suffered a massive BEC attack in August 2019 that cost the company \$37.3 million. The auto parts supplier was tricked into making a large fund transfer into the hackers' bank account.

Threat actors posed as one of the subsidiary's business partners and sent carefully crafted emails to members of the accounting and finance departments. These emails requested that the funds be sent into a specific bank account, which was controlled by the hackers. Soon after the transfer was made, the company's security experts realized that they had been duped. However, by then, it was too late to stop the transfer.



ATTACK

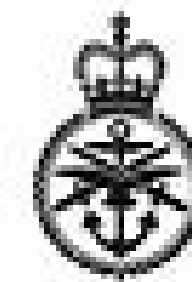
The personal information of an unknown number of serving UK military personnel had been accessed in a significant data breach.

The hack targeted a payroll system used by the Ministry of Defence, which includes names and bank details of both current and some past armed forces members. It is also known that a small amount of personal addresses were also obtained.

There are reports that the attack was from China.

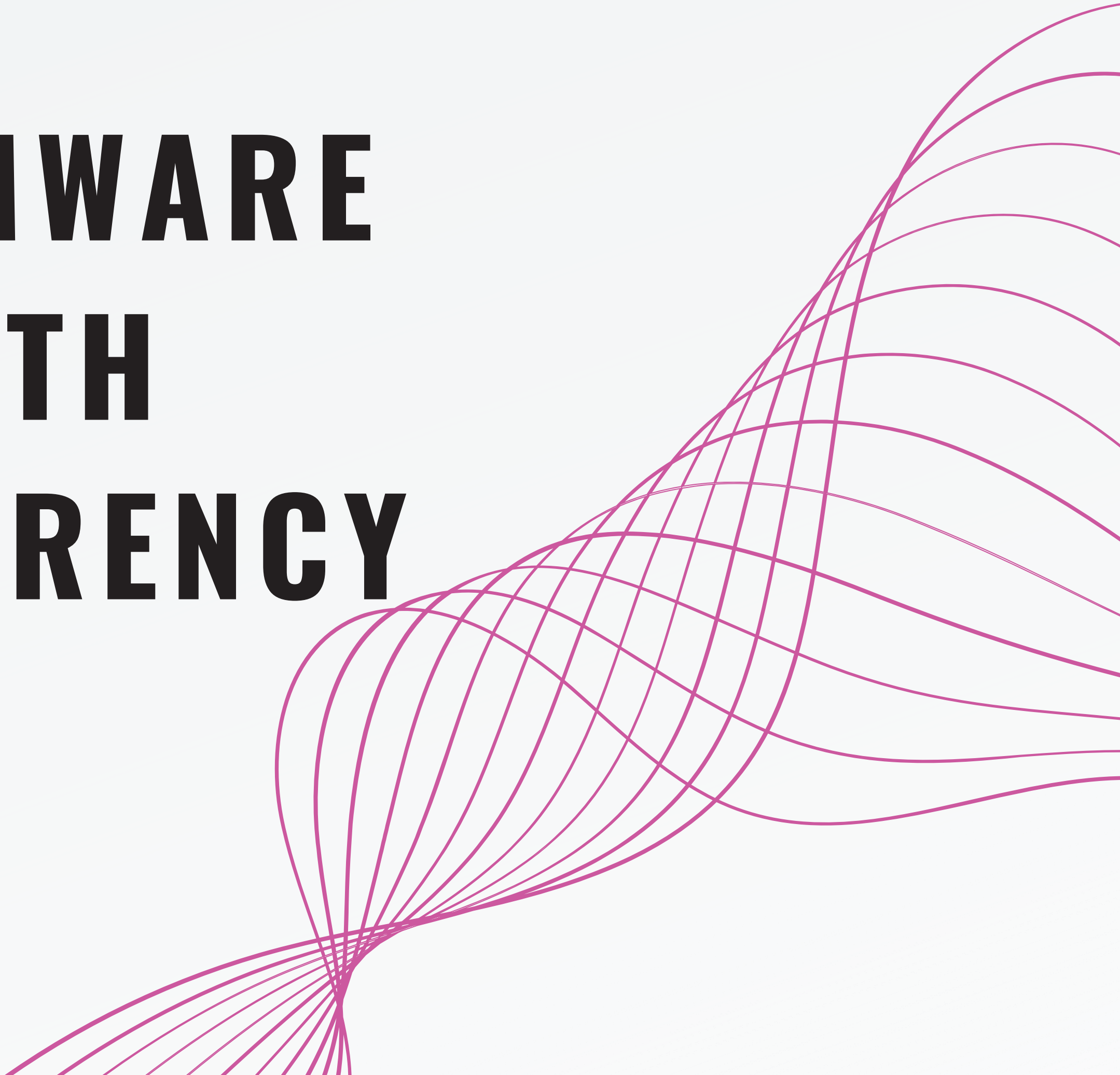
The data, described as "personal HMRC-style information", relates to current and former members of the Royal Navy, Army and Royal Air Force over a period of several years.

The system was managed by an external contractor and no operational MoD data has been obtained.



Ministry
of Defence

Q2. RANSOMWARE ATTACKS WITH CRYPTOCURRENCY



RANSOMWARE ATTACKS



Definition

Ransomware is a type of malware that permanently blocks access to the victim's personal data unless a "ransom" is paid.

While some simple ransomware may lock the system without damaging any files, more advanced malware uses a technique called cryptoviral extortion. It encrypts the victim's files, making them inaccessible, and demands a ransom payment to decrypt them.

In a properly implemented cryptoviral extortion attack, recovering the files without the decryption key is an intractable problem, and difficult-to-trace digital currencies such as paysafecard or Bitcoin and other cryptocurrencies are used for the ransoms, making tracing and prosecuting the perpetrators difficult.

WHY ATTACKERS REQUEST CRYPTOCURRENCY

LACK OF LEGAL JURISDICTION

Cryptocurrency is borderless. Due to this there is no impact on transaction speeds, efficiency or limits.

An attacker could be in one country with the victim in other. As there is no central authority or global compliance standards for these transactions, and they are more often between different countries, attackers usually escape legal repercussions.

HIGH ACCESS & REACH

With cryptocurrency becoming more widely available, exchanges are more common place.

There are affordable currencies becoming available each day.

Merchants are starting to accept cryptocurrency as a method of payment. Due to the wide spread availability, it is making it easier for attackers to demand ransom payments and to quickly dispose of stolen funds.

DIFFICULTY TO DETECT

Even though the records of cryptocurrency transactions are publicly available on the cryptographic ledger of blockchain the identify of the individuals involved is anonymous. Attackers often obfuscate funds to evade detection.

This makes tracking those transactions difficult. Alongside having multiple wallet with each of them having a different address this makes this even more difficult. It is possible however, as evidenced by the \$2.3 million worth of bitcoin which was recovered from Colonials ransom payment by the FBI, supported by blockchain analysis company, Chainalysis.

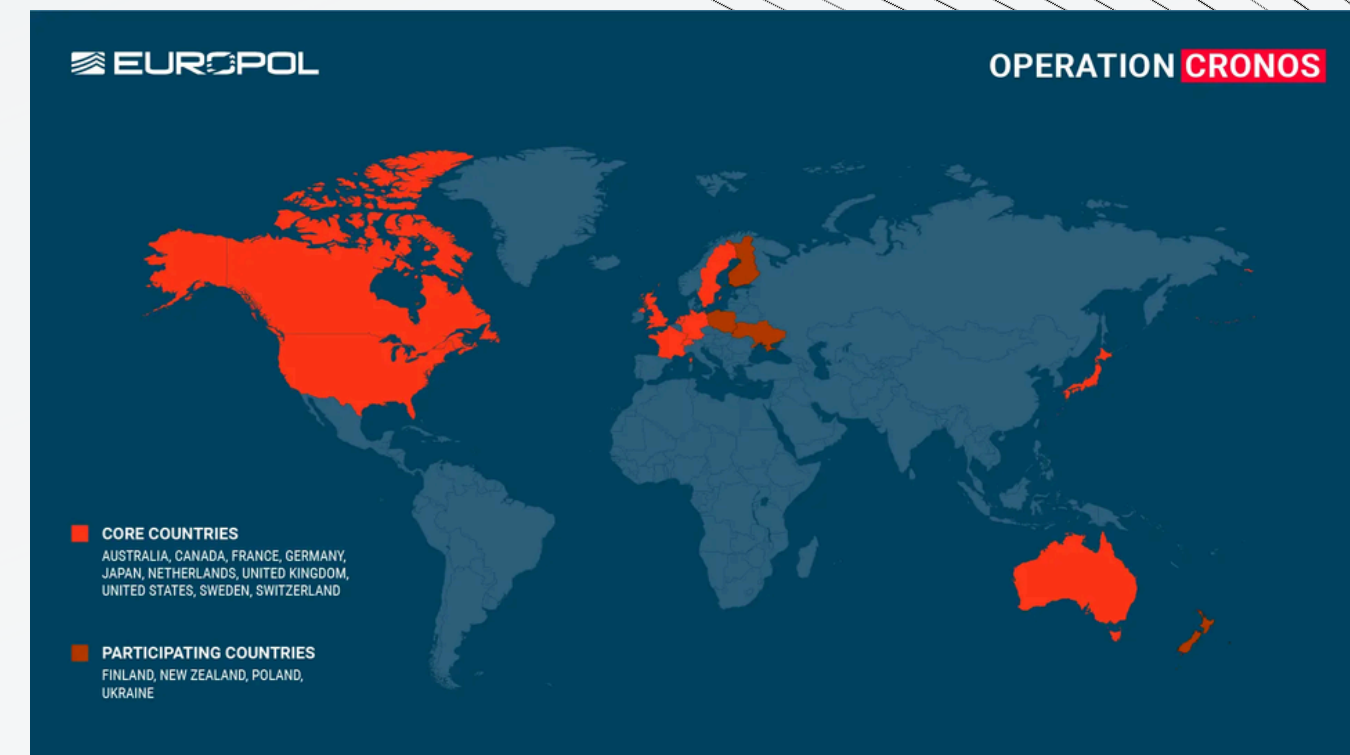
CHALLENGES FOR LAW ENFORCEMENT

As explained in the previous slides this is why many attackers would ask for cryptocurrency as payment in a ransomware attack.

. The instantaneous transaction speeds, lack of global compliance standards and anonymous nature of the transactions means that it is difficult for law enforcement to track.

The fact that these attacks tend to be generated from a different country to the victim proves yet another barrier in bringing the perpetrator to justice due to the different jurisdictions in place across the world.

But it can be done, as seen with Operation Cronos, 10 different countries came together to disrupt the criminal organisation of the LockBit ransom group at every level, damaging their capability and credibility.



[Read about it, here](#)

Q3. LINUX SYSTEMS PURPOSES AND FUNCTIONALITY



FUNCTIONALITY WITH LINUX SYSTEMS

01

● /ETC/PASSWD

This is a text based file that contains all the information of assigned users. They can be viewed by all but any adjustments must be made by the system administrator. It used to also store passwords, however this is now stored within shadow but the command still exists.

username:x:UID:GID:full_name:home_directory:shell

- **username:** The users login name – must be unique
- **x:** This is a placeholder, it used to be for the password in older versions
- **UID:** Unique numerical user ID. Each user has a unique UID in their system
- **GID:** Users primary group ID. This field points to a group in the /etc/group file, which defines group membership
- **full_name:** An optional field for the users name, but can be left blank
- **home_directory:** An absolute path to the users home directory, for example /home/username
- **shell:** Default shell the user will be logged into after authentication, such as /bin/bash or /bin/sh. It can also be set to non-interactive shells (like /usr/sbin/nologin) to disable login.

FUNCTIONALITY WITH LINUX SYSTEMS

username:encrypted_password:last_password_change:min_days:max_days:warn_days:inactive_days:expiration_date

● /ETC/SHADOW

Another text based file that stores the encrypted passwords and other security information for user accounts. It is only accessible by the system administrator

- **username:** The users login name – matching /etc/passwd
- **encrypted_password:** Encrypted form of the user's password. If this field contains a special value such as ! or *, it means the account is locked. It uses hashing algorithms to prevent the password from being easily cracked
- **last_password_change:** The number of days since the last password change
- **min_days:** Minimum number of days before the password can be changed again. This prevents users from repeatedly changing their password to bypass restrictions
- **max_days:** Maximum number of days a password can remain valid. After this period, the user is required to change their password.
- **warn_days:** Countdown until password expires and you'll be warned to change it
- **inactive_days:** Number of days after the password expires that the account will be disabled if the password is not changed.
- **expiration_date:** The absolute date when the account will be disabled. After this date, the user will not be able to log in

Q4. VULNERABILITY SCAN AND ASSESSMENT



VULNERABILITY SCAN

PLANNING & PREPERATION

To avoid network disruptions, ensure compliance and efficiency, it is essential that you layout plan before starting your scan.

- **Define the scope** – Plan on which parts you are going to scan. Get the IP ranges, devices, applications and cloud systems. Are you scanning the entire network or targetted parts?
- **Assets** – Take an inventory of the assets you need based on the scope you would have just identified. By knowing what assets are in place it will help you define the areas in which you need to focus on and limit you missing critcal systems.
- **Permissions** – Ensure you have the right permissions in place from both a legal stand point and administrative one.
- **Time Management** – Try to plan the scan during off-peak hours to minimise the impact on operations.
- **Compliance** – Consider industry-specific regulations that might dictate what scans are required, what systems will be assessed and the frequency.

VULNERABILITY SCAN

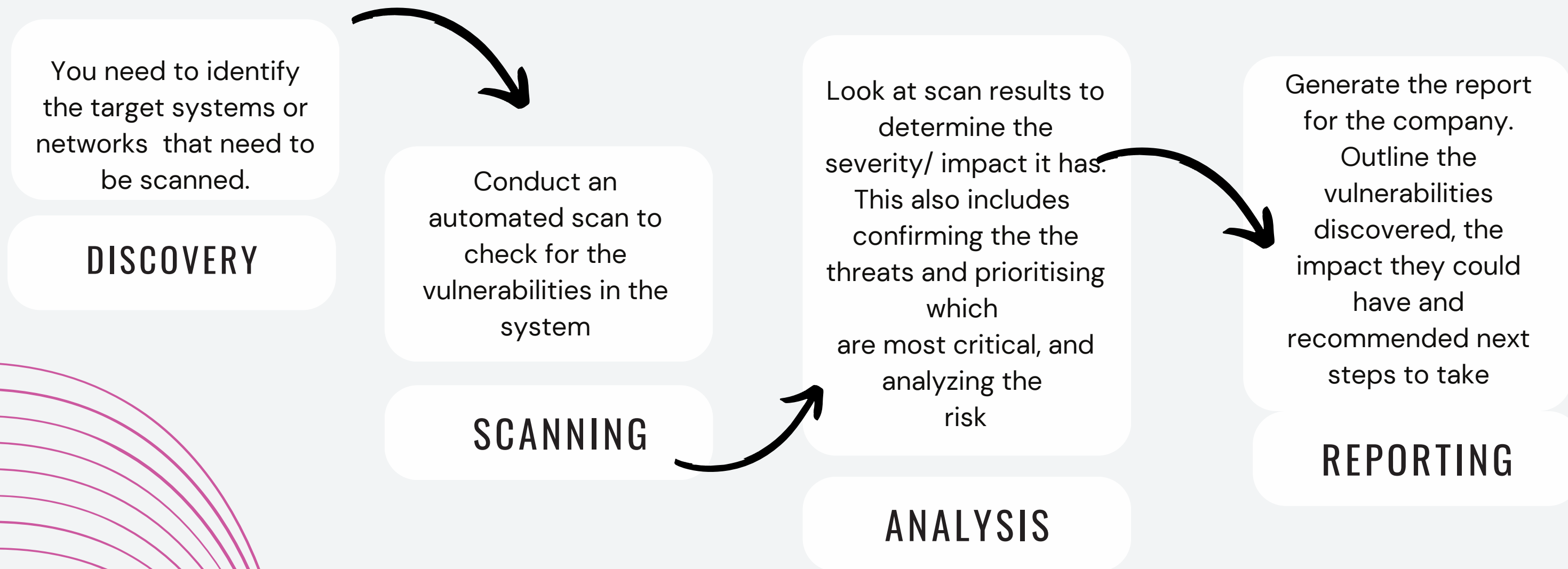
CHOOSING THE RIGHT VULNERABILITY SCANNING TOOL

Things to consider

- **Type of scan:**
 - **Internal:** Simulating a threat made from inside the network
 - **External:** Simulating a threat from an external source (i.e – Unauthorised use from an external person)
- **Credentialed vs Non-Credentialed Scans**
 - **Credentialed:** Use login credentials to provide deeper analysis of systems (e.g., patch levels, configuration issues, misconfigurations). This offers a more comprehensive assessment.
 - **Non-credentialed:** Simulates an external attacker without insider access. It's faster but may not uncover certain vulnerabilities like missing patches.
- **Comprehensive database:** Ensure it is an updated database of CVEs and supports latest threat scanning.
- **Reporting:** It would be helpful to use a tool that can provide clear, actionable reporting which can be used for different audiences.
- **Integration and Automation:** Find a tool that integrates with my existing infrastructure, such as SIEM (Security Information and Event Management) systems or ticketing systems for remediation tracking. Automation can be useful for continuous monitoring.

VULNERABILITY SCAN

Conducting a vulnerability scan



VULNERABILITY SCAN

ANALYSING THE RESULTS

Once the scan is completed, a report of vulnerabilities found will be presented. You would then need to prioritise the most significant risks first.

- **Severity Levels:** I'd need to check the severity level, i.e critical, high, medium, low, based on CVSS (Common Vulnerability Scoring System) scores. Priority would be addressing the critical and high-risk vulnerabilities.
- **False Positives:** Verify any vulnerabilities manually or by using a second tool to cross-check if there are any false positives as sometimes things that are not actual threats get flagged.
- **Context:** A high-risk vulnerability on a public facing server would be priority over the same issue on an internal system with limited access.
- **Prioritise by Impact:** Any vulnerability that could allow remote code execution or privilege escalation, affect public facing systems and/or critical business functions or are actively being exploited or have published exploits would be the greatest priority.
- **System-Specific Recommendations:** Some tools provide remediation guidance specific to the system, including patches, configurations, or other corrective actions.

VULNERABILITY SCAN

REMEDIATION AND MITIGATION

- **Patch Management:** Apply patches to software and systems where vulnerabilities were found. Ensure that all software, especially operating systems and third-party applications, are up to date.
- **Configuration Fixes:** If vulnerabilities are related to weak configurations such as weak passwords, open ports you would need to adjust system settings to mitigate the risk.
- **Mitigation:** If a patch isn't available, look for temporary mitigations, such as restricting network access, disabling vulnerable services, or using virtual patching.
- **Retesting:** After applying fixes, conduct a follow-up scan to ensure the vulnerabilities have been properly remediated.

REPORTING

- **Exec Summary:** Complete a high level overview of the scan, including the number of vulnerabilities found and their severity.
- **Technical Details:** Give a detailed description of each vulnerability found, including its impact and how it was remediated.
- **Remediation Timeline:** Include timelines for fixing issues, with the highest severity being the priority.
- **Compliance Reporting:** If the scan is part of a compliance initiative ensure the report contains the required details to demonstrate adherence to this standard

VULNERABILITY SCAN

● CONTINUOUS MONITORING AND REGULAR SCANNING

Vulnerability management is an ongoing process. New vulnerabilities emerge regularly, so it's essential to establish a routine for scanning and monitoring.

- **Schedule Regular Scans:** Depending on the companies size and risks, scans should be conducted weekly, monthly, or quarterly.
- **Continuous Monitoring:** Consider using tools with continuous vulnerability monitoring, especially in dynamic environments with frequent changes..
- **Penetration Testing:** Combine vulnerability scanning with periodic penetration testing for a more comprehensive security assessment.

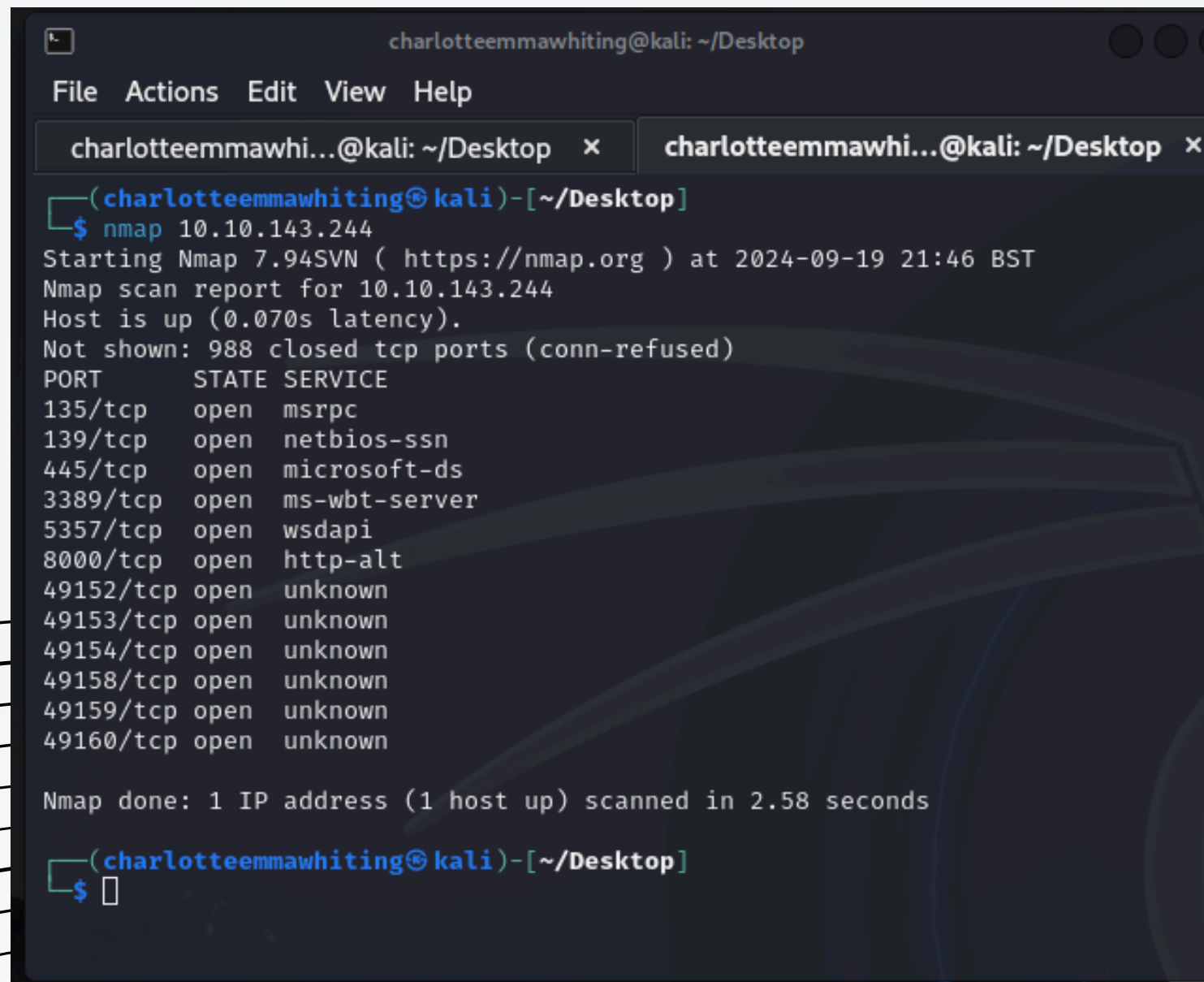
Q5.

RECONNAISSANCE

SCAN



OPEN PORTS



```
charlotteemmawhiting@kali: ~/Desktop
File Actions Edit View Help
charlotteemmawhi...@kali: ~/Desktop x charlotteemmawhi...@kali: ~/Desktop x
(charlotteemmawhiting@kali)-[~/Desktop]
$ nmap 10.10.143.244
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-09-19 21:46 BST
Nmap scan report for 10.10.143.244
Host is up (0.070s latency).
Not shown: 988 closed tcp ports (conn-refused)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
5357/tcp   open  wsdapi
8000/tcp   open  http-alt
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49158/tcp  open  unknown
49159/tcp  open  unknown
49160/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 2.58 seconds
(charlotteemmawhiting@kali)-[~/Desktop]
$
```

By running **\$nmap 10.10.143.244** I can see the following ports are open:

- **135** – Microsoft EPMAP (End Point Mapper), also known as DCE/RPC Locator service used to remotely manage services including DHCP server, DNS server and WINS. Also used by DCOM
- **139** – NetBIOS Session Service
- **445** – Microsoft-DS (Directory Services) SMB file sharing
- **3389** – Microsoft Terminal Server (RDP) officially registered as Windows Based Terminal (WBT)
- **5357** – Web Services for Devices (WSDAPI) (only provided by Windows Vista, Windows 7 and Server 2008)
- **8000** – DynamoDB Local, Django Development Webserver, Python 3 http.server
- **49152 to 49159** – Certificate Management over CMS and Xsan Filesystem Access
- **49160** – Palo Alto Networks' Panorama.

SERVICE OF THE PORTS

By running **\$nmap -sC -sV 10.10.143.244** I get more details on the target.

-sC 'default scripts' alongside -sV 'version detection' will find out the versions of the services I have running, which can help in vulnerability assessment.

- **135** – Service = msrpc / Version = Microsoft windows RPC
- **139** – Service = netbios.snn / Version = Microsoft Windows netbios.snn
- **445** – Service = microsoft-ds / Version = Windows 7 Professional 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
- **3389** – Service = ssl/ms-wbt-server?
- **5357** –Service = http / Version = Microsoft HTTPAPI httpd 2.0
- **8000** – Service http / Version = Icecast streaming media server
- **49152 to 49160** – Service = msrpc / Version = Microsoft Windows RPC

```
charlotteemmawhiting@kali: ~/Desktop
File Actions Edit View Help
charlotteemmawhiting@kali: ~/Desktop x charlotteemmawhiting@kali: ~/Desktop x

(charlotteemmawhiting@kali)~[~/Desktop]
$ nmap -sC -sV 10.10.143.244
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-09-19 22:08 BST
Nmap scan report for 10.10.143.244
Host is up (0.034s latency).
Not shown: 988 closed tcp ports (conn-refused)
PORT      STATE SERVICE          VERSION
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn      Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds      Windows 7 Professional 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
3389/tcp    open  ssl/ms-wbt-server?
| rdp-ntlm-info:
|   Target_Name: DARK-PC
|   NetBIOS_Domain_Name: DARK-PC
|   NetBIOS_Computer_Name: DARK-PC
|   DNS_Domain_Name: Dark-PC
|   DNS_Computer_Name: Dark-PC
|   Product_Version: 6.1.7601
|_  System_Time: 2024-09-19T21:03:13+00:00
| ssl-cert: Subject: commonName=Dark-PC
| Not valid before: 2024-09-18T20:24:42
|_ Not valid after: 2025-03-20T20:24:42
|_ ssl-date: 2024-09-19T21:03:19+00:00; -7m02s from scanner time.
5357/tcp    open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Service Unavailable
8000/tcp    open  http             Icecast streaming media server
|_ http-title: Site doesn't have a title (text/html).
49152/tcp   open  msrpc            Microsoft Windows RPC
49153/tcp   open  msrpc            Microsoft Windows RPC
49154/tcp   open  msrpc            Microsoft Windows RPC
49158/tcp   open  msrpc            Microsoft Windows RPC
49159/tcp   open  msrpc            Microsoft Windows RPC
49160/tcp   open  msrpc            Microsoft Windows RPC
Service Info: Host: DARK-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ clock-skew: mean: 52m57s, deviation: 2h14m09s, median: -7m03s
| smb2-security-mode:
|   2.1.0:
|_   Message signing enabled but not required
|_ nbstat: NetBIOS name: DARK-PC, NetBIOS user: <unknown>, NetBIOS MAC: 02:dc:e0:11:aa:5d (unknown)
| smb2-time:
|   date: 2024-09-19T21:03:13
|_  start_date: 2024-09-19T20:24:41
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|   OS: Windows 7 Professional 7601 Service Pack 1 (Windows 7 Professional 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1:professional
|   Computer name: Dark-PC
|   NetBIOS computer name: DARK-PC\x00
```

```
3389/tcp    open  ssl/ms-wbt-server?
| rdp-ntlm-info:
|   Target_Name: DARK-PC
|   NetBIOS_Domain_Name: DARK-PC
|   NetBIOS_Computer_Name: DARK-PC
|   DNS_Domain_Name: Dark-PC
|   DNS_Computer_Name: Dark-PC
|   Product_Version: 6.1.7601
|_  System_Time: 2024-09-19T21:03:13+00:00
| ssl-cert: Subject: commonName=Dark-PC
| Not valid before: 2024-09-18T20:24:42
|_ Not valid after: 2025-03-20T20:24:42
|_ ssl-date: 2024-09-19T21:03:19+00:00; -7m02s from scanner time.
```

Server info from port 3389

HOSTNAME

Within the results, you will also find out the host name repeatedly here...

NetBIOS_Domain_Name: DARK PC
NetBIOS_Computer_Name: DARK-PC
DNS_Domain_Name: DARK-PC
DNS_Computer_Name: Dark-PC

OPERATING SYSTEM & VERSION

You'll also find the system details and version:

Windows 7 Professional 7601 Service Pack 1 (Version 6.1)

```
Nmap scan report for 10.10.143.244
Host is up (0.034s latency).
Not shown: 988 closed tcp ports (conn-refused)
PORT      STATE SERVICE          VERSION
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn      Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds     Windows 7 Professional 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
3389/tcp   open  ssl/ms-wbt-server?
|_ rdp-ntlm-info:
|   Target_Name: DARK-PC
|   NetBIOS_Domain_Name: DARK-PC
|   NetBIOS_Computer_Name: DARK-PC
|   DNS_Domain_Name: Dark-PC
|   DNS_Computer_Name: Dark-PC
|   Product_Version: 6.1.7601
|_ System_Time: 2024-09-19T21:03:13+00:00
|_ ssl-cert: Subject: commonName=Dark-PC
|_ Not valid before: 2024-09-18T20:24:42
|_ Not valid after: 2025-03-20T20:24:42
|_ ssl-date: 2024-09-19T21:03:19+00:00; -7m02s from scanner time.
5357/tcp   open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Service Unavailable
8000/tcp   open  http             Icecast streaming media server
|_ http-title: Site doesn't have a title (text/html).
49152/tcp  open  msrpc            Microsoft Windows RPC
49153/tcp  open  msrpc            Microsoft Windows RPC
49154/tcp  open  msrpc            Microsoft Windows RPC
49158/tcp  open  msrpc            Microsoft Windows RPC
49159/tcp  open  msrpc            Microsoft Windows RPC
49160/tcp  open  msrpc            Microsoft Windows RPC
Service Info: Host: DARK-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ clock-skew: mean: 52m57s, deviation: 2h14m09s, median: -7m03s
|_ smb2-security-mode:
|   2.1:0:
|_   Message signing enabled but not required
|_ nbstat: NetBIOS name: DARK-PC, NetBIOS user: <unknown>, NetBIOS MAC: 02:dc:e0:11:aa:5d (unknown)
|_ smb2-time:
|   date: 2024-09-19T21:03:13
|   start_date: 2024-09-19T20:24:41
|_ smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb-os-discovery:
|   OS: Windows 7 Professional 7601 Service Pack 1 (Windows 7 Professional 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1:professional
|   Computer name: Dark-PC
|   NetBIOS computer name: DARK-PC\x00
|   Workgroup: WORKGROUP\x00
|_ System time: 2024-09-19T16:03:13-05:00

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
```